

SOC / ENTERPRISE PENTEST HOMELAB

SOC Homelab

Master Documentation

Beknopte, samengevoegde referentie voor het volledige SOC Homelab project — architectuur, systemen, beslissingen, guides, troubleshooting, tijdlijn en attack scope.

Auteur: Joost Hebly · **Samengesteld:** 13 juli 2026 · **Bron:** git repo /Homelab (docs/) + live labverificatie + OPNsense-audit

Statuslabels:  geverifieerd/actueel ·  open actiepunt ·  gepland, nog niet gebouwd.

Table of contents

1. Project overview & purpose

2. Architecture & network design

- Network map
- IP address table
- Virtual networks (libvirt)
- Physical host
- Traffic mirroring (`soc-mirror.service`)
- DNS and DHCP
- Security principles
- Planned network improvements (not yet built)

3. Systems in detail

- 3.1 Bazzite host & virtualization
- 3.2 OPNsense (firewall/gateway)
- 3.3 DC01 — Active Directory Domain Controller
- 3.4 WIN11-01 — Windows 11 workstation
- 3.5 ubuntu-server-01 — Linux server, active Red Team target
- 3.6 Security Onion — SOC platform
- 3.7 Kali Linux — Red Team workstation
- 3.8 Metasploitable2 — vulnerable training target

4. Architecture, security & AI rules

- Why these technologies were chosen
- AI rules (binding on any AI assistant working on this project)
- Core security principles
- Incident response phases

5. Operational guides

- 5.1 Starting/stopping the lab
- 5.2 Connecting to systems
- 5.3 Security Onion / Kibana / Fleet in the browser
- 5.4 Network ports & firewall hostgroups reference
- 5.5 Desktop launchers
- 5.6 Quick reference

6. Detection use cases & incident response

- 6.1 What this SOC should detect
- 6.2 Incident response runbook

6.3 Detection validation plan

7. Troubleshooting history

7.6 DC01 Fleet health & Sysmon telemetry (2026-07-13)

8. Project timeline

9. Asset inventory

Physical host

Virtual machines

Active Directory identity inventory

Software versions

Access methods (no passwords stored here)

Open items

10. Glossary

11. Current project status / what's next

✅ Done

⚠️ Open

❌ Planned

Keeping this current

12. Attack scope: agreed Red Team test plan

Tier 1 — Reconnaissance & enumeration

Tier 2 — Exploitation of intentionally-vulnerable targets

Tier 3 — Active Directory attack chain (after the escalation-path build)

Document index

1. Project overview & purpose

SOC Homelab (originally "Fortress Bazzite") is Joost Hebly's private cybersecurity training environment — a real SOC, built and operated end-to-end, including the real problems that come with it.

Focus areas: **Blue Team** (Security Onion/Kibana monitoring, incident response, detection engineering), **Red Team** (vulnerability testing, exploitation, AD attacks), realistic **Active Directory**, general **network defense**. Also a portfolio piece — Joost produces formal reports/documentation from it alongside the working lab.

Origin: started as Fortress Bazzite (self-built Suricata+Zeek+Wazuh stack, design doc 2026-07-05). In practice, **Security Onion** was chosen instead — same goal, one bundled platform (it already includes Suricata, Zeek, and Fleet/Elastic Agent in place of Wazuh). Original detection goals carried forward — [§6](#).

AI collaboration: ChatGPT for architecture/planning/strategy, Claude Code for terminal work/documentation/scripts/implementation. Both operate under the AI rules in [§4](#). **Golden rule:** no destructive changes without approval; all changes documented.

2. Architecture & network design

Network map



Security Onion has two NICs: `pentest-lab` (.30, Fleet/Kibana/SSH/web) and `monitor-net` (no IP, mirrored traffic only).

IP address table

IP	System	virsh VM name	SSH alias	SSH user	Status
192.168.50.1	OPNsense (firewall/gateway)	OPNsense-FW	opnsense	root	✓
192.168.50.10	DC01 (AD, PDC Emulator, domain pentest.lab)	DC01	dc01	Administrator	✓
192.168.50.20	WIN11-01 (domain-joined as DESKTOP-EFKB8GQ)	WIN11-01	(none — no SSH)	—	✓
192.168.50.30	Security Onion 3.1.0 (SIEM/IDS/Fleet)	SOC-SecurityOnion	security-onion	socadmin	✓
192.168.50.40	ubuntu-server-01 (live OWASP Juice Shop on :3000)	ubuntu-server-01	ubuntu-server	ubuntu (key auth not set up)	✓
192.168.50.50	Kali Linux (Red Team)	ATTACK-Kali ⚠️ leading space in the name	kali	blue1	✓
192.168.50.70	Metasploitable2 (vulnerable target)	Target-Metasploitable2	(none)	—	✓

Known naming bug: the VM name ATTACK-Kali has a literal leading space in libvirt (broke name-matching scripts once — §7). New scripts should match on UUID instead.

IP authority: docs/ASSET_INVENTORY.md and NETWORK.md (2026-07-13) are authoritative — older docs and the 2026-07-09 daily report contain now-superseded IPs for Security Onion, Kali, ubuntu-server-01, and Metasploitable2; not repeated here.

Virtual networks (libvirt)

Network	Purpose
pentest-lab	Main network, 192.168.50.0/24, isolated. No libvirt-native DHCP — OPNsense handles this exclusively.
monitor-net	Isolated, no IP addressing, exclusively for traffic mirroring to Security Onion.
default	Standard libvirt network, not used by lab VMs.

Physical host

Bazzite Linux. CPU: Intel Core i9-11900K (8c/1s) · GPU: NVIDIA RTX 3090 · RAM: 62 GiB · WiFi: Intel AX210 (Wi-Fi 6E) · Virtualization: KVM/QEMU/libvirt/virt-manager. All ✓ live-verified. ⚠️ WiFi PCI-

passthrough to Kali and host-level Docker not reconfirmed — Juice Shop's actual location is `ubuntu-server-01` , not the host.

Traffic mirroring (`soc-mirror.service`)

Event-driven (`scripts/soc-mirror.sh` , triggered by a libvirt qemu hook on every VM start/stop) — no polling timer. When a `pentest-lab` VM starts, its traffic mirrors to Security Onion's `monitor-net` interface; stale rules clean up automatically on Security Onion restart. Status: `scripts/soc-mirror.sh --status` .

DNS and DHCP

DHCP: Kea DHCPv4 on OPNsense, LAN interface only. Subnet `192.168.50.0/24` , dynamic pool `.100 - .200` , 7 static reservations (one per lab VM by MAC — the canonical IP plan, see [§9](#)). Option 6 pushes `192.168.50.10` (DC01) as DNS server. Kea DHCPv6 exists but has no interface assigned (inactive). **DNS:** DC01 (AD DNS) authoritative for `pentest.lab` ; OPNsense's Unbound forwards the `pentest.lab` domain specifically to `192.168.50.10` and has one host override (`dc01.pentest.lab` → `.10`), everything else resolved/forwarded normally. Confirmed 2026-07-13 via a full read-only OPNsense audit — full detail: `docs/OPNSENSE_AUDIT_2026-07-13.md` .

Security principles

Segmentation (`monitor-net` fully separate from `pentest-lab`) · least privilege (Security Onion hostgroups) · monitor first, block second · every change documented.

Planned network improvements (not yet built)

VLAN segmentation · separate management/attack networks · additional Windows clients · honeypots · more SOC sensors.

3. Systems in detail

All facts below are live-verified 2026-07-13 unless marked otherwise.

3.1 Bazzite host & virtualization

Physical KVM/QEMU/libvirt/virt-manager host, doubling as Joost's daily desktop. Storage: qcow2 (snapshots, thin provisioning). Basic lifecycle:

```
virsh list --all
virsh start VMNAME
virsh shutdown VMNAME      # graceful; --destroy only if stuck
```

⚠️ QEMU guest agent isn't configured by default per VM — install/enable in-guest before relying on guest-management features.

3.2 OPNsense (firewall/gateway)

Central firewall/gateway for 192.168.50.0/24 — firewall, routing, DHCP, DNS forwarding. IP `.1`. SSH alias `opnsense`, user `root`, password-only login by design (no key auth configured — confirmed via the OPNsense audit, not a regression). OPNsense 26.1.11_6-amd64 / FreeBSD 14.3. No custom firewall rules beyond the LAN/WAN defaults (no inter-VM segmentation at this layer), no VPN configured, single local admin user. Full configuration audit: `docs/OPNSENSE_AUDIT_2026-07-13.md`.

3.3 DC01 — Active Directory Domain Controller

Windows Server 2022 Standard Evaluation. Domain `pentest.lab`, DC01 is PDC Emulator (only DC). IP `.10`. SSH alias `dc01` / `Administrator`. Timezone `W. Europe Standard Time` (cosmetic; UTC clock is authoritative).

AD structure is built (not just planned):

```
DC=pentest,DC=lab
├─ OU=Domain Controllers    (DC01)
├─ OU=Admins                (IT Admin 01)
├─ OU=AD-Users              (soctest, Helpdesk 01, Employee 01, Manager 01, HR 01, Finance 01)
├─ OU=Workstations          (empty)
├─ OU=Servers               (empty)
├─ OU=Groups                (SOC-Analysts: soctest · Helpdesk: no members)
└─ OU=Service-Accounts      (SQL Service)
```

⚠️ **Known gaps** (real, deliberately left as-is pending [§12](#)): `OU=Workstations` / `OU=Servers` empty (WIN11-01 not moved in); `IT Admin 01` has no elevated group membership despite its name/OU;

Helpdesk group has no members; role accounts (Employee/Manager/HR/Finance 01) are undifferentiated Domain Users .

Monitoring: Elastic Agent + Sysmon 15.21 (SwiftOnSecurity config) enrolled in Fleet, **Healthy** — full root-cause history in [§7.6](#). NTP via pool.ntp.org ; vmictimesync disabled (was fighting NTP at boot).

3.4 WIN11-01 — Windows 11 workstation

IP .20 , no SSH. Domain-joined as DESKTOP-EFKB8GQ (never renamed, still in default Computers container). Only TCP 135 reachable — Windows Firewall blocks SMB/RDP/WinRM/139 from the lab network; no remote-admin path except the VM console. ⚠ Intended training purpose still undecided beyond "becomes a target after cleanup" — [§12](#).

3.5 ubuntu-server-01 — Linux server, active Red Team target

IP .40 — confirmed via OPNsense's own Kea DHCP reservation database plus a fresh live re-check ([§4/ docs/OPNSENSE_AUDIT_2026-07-13.md](#)); briefly seen on .100 (dynamic pool) earlier the same day, before its reservation was honored. SSH alias ubuntu-server / ubuntu ; key auth not yet working — password or ssh-copy-id needed. Runs **OWASP Juice Shop live** on port 3000 (HTTP-confirmed, not a leftover — it's up right now).

3.6 Security Onion — SOC platform

Security Onion 3.1.0 standalone. IP .30 , SSH security-onion / socadmin (key auth works). OS timezone intentionally UTC (web UI already renders local time). Own internal firewall — hostgroups gate portgroups, membership in one grants nothing in another (root cause of the DC01 outage, [§7.6](#); reference: [§5.4](#)). Bundles Suricata, Zeek, Elasticsearch, Kibana, Fleet, Hunt.

3.7 Kali Linux — Red Team workstation

VM ATTACK-Kali (leading space). IP .50 , SSH kali / blue1 (key auth works). Vulnerability scanning, exploitation, network analysis — authorized use inside this isolated lab only.

3.8 Metasploitable2 — vulnerable training target

VM Target-Metasploitable2 . IP .70 . Stock, unmodified port fingerprint confirmed (FTP/SSH/Telnet/SMTP/DNS/HTTP/rpcbind/SMB/rexec-rlogin-rsh/Java-RMI/ingreslock/NFS/ProFTPD-backdoor/MySQL/distccd/PostgreSQL/VNC/X11/UnrealIRCd/AJP/Tomcat). No ACPI shutdown support — lab-stop.sh force-stops it after 60s (expected).

4. Architecture, security & AI rules

Why these technologies were chosen

Decision	Choice	Core reason
Host OS	Bazzite Linux	Modern Linux + NVIDIA + gaming + virtualization on one machine
Virtualization	KVM/QEMU/libvirt/virt-manager	Native Linux, full control, deeper understanding than a turnkey hypervisor
Firewall	OPNsense	Realistic enterprise firewall/routing/DHCP/DNS practice
SOC platform	Security Onion	Complete SIEM+IDS+NSM bundle, superseding a hand-rolled stack
Identity	Windows Server AD (DC01)	Realistic detection/attack scenarios (logins, privilege escalation, lateral movement)
Version control	Git	History, recovery points, professional change tracking
Secrets storage	Separate <code>Secure/SOC-Secure.img</code> , never in Git	Docs can be shared; secrets must never enter Git history
AI assistance	ChatGPT (planning) + Claude Code (implementation)	Support tools, not decision-makers — bound by the rules below

AI rules (binding on any AI assistant working on this project)

Merged from `AI_ACCESS_POLICY.md`, `PROJECT_RULES.md`, `CLAUDE.md`. Claude Code acts as a **junior SOC engineer and documentation assistant**, not an autonomous administrator — documentation is treated as more reliable than its own memory; source of truth: `README.md`, `PROJECT_RULES.md`, `AI_ACCESS_POLICY.md`, `docs/INDEX.md`, `docs/guides/`, `docs/troubleshooting/`, `docs/decisions/`.

Allowed: read/analyze documentation and configs, explain commands, suggest improvements, write/maintain documentation, troubleshoot (research, diagnosis, proposing fixes). AI assists — it doesn't replace administrator decisions.

Never: store or write down passwords/secrets/API keys/private keys/tokens anywhere; commit credentials; modify firewall rules or critical infrastructure without approval; delete or destructively change anything without confirmation; ignore previous documented decisions.

Credentials: never in Git or markdown, not even temporarily. Live only in `Secure/SOC-Secure.img`, opened manually by the administrator — an assistant never touches it. The user enters passwords themselves when needed.

Infrastructure change procedure: explain what will change → explain risk/impact → snapshot/backup → get explicit confirmation → execute the smallest sufficient change → document

the result.

Troubleshooting method: check existing docs → identify the affected system → review prior troubleshooting cases → explain root cause → apply the smallest safe fix → update documentation.

General behavior: respect prior decisions, preserve existing architecture, ask before destructive (even reversible) actions, document discoveries as they happen, prefer safe/reversible solutions, explain commands and verify results rather than assuming success.

Read-only investigation is in-scope without prior confirmation — e.g. using `virsh`, ARP tables, unauthenticated port probes, or already-working passwordless SSH to verify facts for documentation. Anything that *changes* the lab (firewall, AD objects, service state) still needs the full change procedure above.

Final principle: documented, reproducible, secure, understandable — documentation first, automation second, security always.

Core security principles

Least privilege · defense in depth (OPNsense + Security Onion hostgroups + host controls) · network isolation (192.168.50.0/24 is isolated because it hosts attack tooling and deliberately vulnerable machines) · documentation before/with automation · backups before changes · monitoring as the foundation, not an add-on · all offensive testing stays inside the lab boundary.

Incident response phases

Identification → Analysis → Containment → Recovery → Lessons learned. Operationalized in the runbook — [§6.2](#).

5. Operational guides

5.1 Starting/stopping the lab

Preferred: **Pentest Lab Start / Stop** desktop launchers (all 7 VMs, correct order). Command line:

```
~/Homelab/scripts/lab-start.sh
~/Homelab/scripts/lab-stop.sh
```

Single VM: `virsh -c qemu:///system start|shutdown <vm-name>` — note the leading space in `ATTACK-Kali` ([§9](#)). `lab-start.sh` is idempotent; `lab-stop.sh` tries graceful ACPI shutdown first (60s/180s timeout) before force-killing.

5.2 Connecting to systems

SSH Alle Machines launcher opens one Konsole tab per machine, or directly:

```
ssh opnsense
ssh dc01
ssh security-onion
ssh kali
ssh ubuntu-server
```

Homelab VM Manager opens virt-manager on `qemu:///system`. **Key status:** only `kali`, `security-onion`, `dc01` are passwordless; `opnsense` and `ubuntu-server` still prompt/fail — see [§9](#) open items.

5.3 Security Onion / Kibana / Fleet in the browser

Security Onion Operator launcher opens a persistent Playwright/Chromium profile with every key page as a tab (Overview, Hunt, Detections, Cases, Grid, Kibana, Fleet), driven via a local CDP port (never exposed beyond localhost). First run waits for manual login to both Security Onion and Kibana/Fleet (two separate logins); session persists in `browser/profile/` (never in Git). Everything built so far is **read-only** — nothing can modify Fleet, detection rules, or Security Onion config.

Fleet status report: `~/Homelab/scripts/soc-web-audit.sh` → Markdown report in `browser/artifacts/`.

 **Recorded incident:** a script once printed a live session cookie into terminal output via a raw `context.request` call. No external leak, but fixed immediately (daemon restarted, session invalidated) and all API calls now route through `fetchJsonInPage()`, which runs inside the authenticated page so cookies never pass through this project's own code. Don't reintroduce raw out-of-page HTTP calls without the same care.

5.4 Network ports & firewall hostgroups reference

Security Onion's **own** firewall (separate from OPNsense) — reconstructed from

```
/opt/so/saltstack/default/salt/firewall/{defaults,soc_firewall}.yaml .
```

Portgroup	Port(s)	Purpose
elastic_agent_control	8220	Fleet Server checkin
elastic_agent_data	5055	Data ingest
elastic_agent_update	8443	Agent updates
endgame	3765	Elastic Defend/Endpoint output
beats_5044 / 5644 (SSL) / 5066 / 5056	—	Logstash beats input
kibana	5601	Kibana web UI
elasticsearch_rest	9200	Elasticsearch REST

Key hostgroups: `analyst` (web UI/Kibana users) · `elastic_agent_endpoint` (Fleet checkin) · `beats_endpoint` / `_ssl` (log shipping) · `endgame` (Elastic Defend) · `manager` / `receiver` / `sensor` / `standalone` (grid roles) · `desktop` (admin workstations, like `analyst` plus extras).

A normal endpoint with Elastic Agent needs *all three* of `elastic_agent_endpoint` , `beats_endpoint` , and `endgame` — `analyst` alone is not enough; one hostgroup grants nothing in another.

```
sudo so-firewall includehost <hostgroup> <ip>
sudo so-firewall apply          # additive; so-firewall removehost <ip> to strip entirely
```

Read-only inspection: `cat /opt/so/log/so-firewall.log` , `ss -tlnp` . From another host: `Test-NetConnection -ComputerName 192.168.50.30 -Port 8220` .

5.5 Desktop launchers

Launcher	Purpose
Pentest Lab Start / Stop	Start/stop all 7 VMs in order, via Konsole (<code>--hold</code>)
SSH Alle Machines	One Konsole window, independent tab per machine
Homelab VM Manager	virt-manager on <code>qemu:///system</code>
Security Onion Operator	Persistent browser session — §5.3

Bazzite has no `gnome-terminal` — all terminal launchers use Konsole specifically.

SSH config (`~/.ssh/config`):

Alias	Host	User	Status
opnsense	.1	root	Password-only, currently not even password-prompting reliably
dc01	.10	Administrator	Key auth works
security-onion	.30	socadmin	Key auth works
kali	.50	blue1	Key auth works
ubuntu-server	.40	ubuntu	Key auth not set up

WIN11-01 excluded (no SSH server, normal for Windows 11).

5.6 Quick reference

```
# Sysmon test event on DC01, then check Hunt (Last 15 Minutes):  
# host.name:"dc01" AND event.dataset:"windows.sysmon_operational"  
Start-Process -FilePath 'cmd.exe' -ArgumentList '/c echo test' -Wait  
  
~/Homelab/scripts/soc-mirror.sh --status           # mirroring status  
ssh security-onion "tail -20 /opt/so/log/so-firewall.log"
```

6. Detection use cases & incident response

6.1 What this SOC should detect

✓ present (works once traffic/logs arrive) · ⚠ should work via default rulesets, not yet deliberately confirmed · ✗ needs custom rules, not built.

Detection	Status
ICMP ping sweeps / TCP scans (SYN/FIN/NULL/XMAS) / UDP scans	⚠
OS fingerprinting / banner grabbing	⚠ (Zeek connection logs, no dedicated alert)
SSH / FTP / SMB brute force	⚠ (SMB relevant especially toward DC01)
Suspicious DNS requests	⚠ (Zeek dns.log ; Sysmon event 22 on DC01)
Known exploit signatures / reverse shells / Metasploit indicators	⚠ (Suricata rulesets; Sysmon process-creation for host-side)
SQLi / command injection / directory traversal	⚠ (Suricata web-attack rulesets)

Host-based (Sysmon on DC01): Process Create (1), Network Connection (3), File Create (11), DNS Query (22) — all ✓ confirmed with test events. Other event types (registry, image load) — ⚠ covered by config, not individually tested. Elastic Defend also produces its own detections since the 2026-07-13 firewall fix.

How to test (Purple Team style): run a harmless version of the technique from Kali, check Security Onion Hunt/Detections. Example:

```
for i in 1 2 3 4 5; do ssh -o ConnectTimeout=3 -o BatchMode=yes nope@192.168.50.40; done
# Hunt: destination.ip:"192.168.50.40" AND event.dataset:*ssh*
```

6.2 Incident response runbook

Fixed procedure for any alert — real, test, or exercise:

- Confirm** — Security Onion Alerts/Detections: which rule, source/destination, when (SO shows local time, +02:00 summer), how often.
- Context** — Hunt: `source.ip:"<IP>" OR destination.ip:"<IP>"` . Known lab system ([§9](#))? Deliberate test running (docs/daily/)? Anything else at that time?
- Host check** (if SSH-reachable) — logs/processes, Sysmon events around the timestamp. Investigating is always fine independently; changing/restarting/isolating needs a quick explanation first unless already agreed.
- Record** — write up in docs/daily/YYYY-MM-DD/rapport.md regardless of outcome; genuine new technical problems also get a docs/troubleshooting/ doc.

5. **If real** — don't panic (lab is isolated); consider isolating via `virsh` (explain first); preserve evidence before cleanup; document as step 4.

Quick Hunt queries: `host.name:"<lowercase-name>" · ... AND event.module:"windows" · ... AND event.dataset:"windows.sysmon_operational" · source.ip:"<ip>" OR destination.ip:"<ip>"` . ⚠️
Hostnames index lowercase (`dc01`), even though Fleet displays capitalized.

6.3 Detection validation plan

Planned, execution deferred to the §12 test session — every ⚠️ above gets tested there rather than in a separate pass: Tier 1 (recon) covers scans/sweeps/fingerprinting/DNS; Tier 2 (Metasploitable2/Juice Shop exploitation) covers brute force, exploit signatures, reverse shells, Meterpreter, SQLi/injection; Sysmon "other" event IDs get tested on DC01 or WIN11-01 once it's a target. Method: run technique → check Hunt → flip ⚠️ to ✅/❌ with the query and evidence used. Also planned: one full runbook dry-run (§6.2) against a real alert from that pass, logged in `docs/daily/` .

7. Troubleshooting history

Real problems from building this lab. Full evidence/commands/rollback steps live in `docs/troubleshooting/0N_*.md` — this is the summary.

#	Problem	Root cause	Fix / lesson
7.1	QEMU guest agent not configured	Not installed/enabled in-guest, channel not configured	Install + enable + configure channel. Lesson: a running VM ≠ working guest integration — test explicitly.
7.2	virt-manager VM setup	Storage/display quirks	Standardized on qcow2; SPICE issues traced to guest tooling, not hardware. Snapshot before risky changes.
7.3	OPNsense network debugging	Firewall issues masquerading as app/DNS problems	Verify bottom-up: interface → IP → gateway → DNS → firewall. DNS misconfig was repeatedly the real AD root cause.
7.4	Security Onion installation	Under-provisioned resources	SOC platforms need materially more RAM/CPU/storage than an ordinary server. A SOC is only as useful as the telemetry reaching it.
7.5	DC01 AD setup	—	DNS is the foundation AD depends on. Snapshot before promoting to DC (hard to cleanly undo).
7.7	<code>soc-mirror.sh</code> libvirtd deadlock	Synchronous <code>virsh</code> callback from inside a libvirt qemu hook could hang libvirtd	Detached the reconciler via <code>systemd-run --no-block --collect</code> .
7.8	libvirt/OPNsense DHCP conflict (2026-07-09)	libvirt's own DHCP collided with OPNsense's; <code>virbr10</code> claimed OPNsense's own IP	Stripped libvirt's <code><ip></code> / <code><dhcp></code> from the network definition — OPNsense is sole DHCP/DNS/gateway authority. Host got a separate mgmt IP (.254) restored at boot.

7.6 DC01 Fleet health & Sysmon telemetry (2026-07-13)

The largest case — three independent, stacked root causes behind one symptom ("DC01 Offline in Fleet"). Recurring: a 2026-07-10 "fix" was a non-persistent `iptables` rule that any `so-firewall apply /reboot` silently discarded.

- Firewall hostgroups** — DC01 was only ever added to `analyst`, never `elastic_agent_endpoint` / `beats_endpoint` / `endgame` (each hostgroup only grants its own ports — see [§5.4](#)). Fixed with `so-firewall includehost` for all three (additive), `so-firewall apply`.
- ~9h clock skew** — `vmictimesync` was fighting NTP at every boot (DC01, as PDC Emulator, doesn't behave like an ordinary NTP client). Disabled the service, forced `w32tm /resync`, added a boot-time scheduled task. Side effect: the skew had poisoned Logstash's dead-letter queue with rejected

future-timestamped events — explains why `HEALTHY`-reporting agents still showed no data.

Lesson: agent- `HEALTHY` proves shipping, not acceptance.

3. **Sysmon never installed** — Fleet policy expected `windows.sysmon_operational` data that could never arrive. Installed Sysmon 15.21 + SwiftOnSecurity config.

Verified: survives Elastic Agent restart, two DC01 reboots, and a full Security Onion reboot. Rollback procedures (firewall/clock/Sysmon/timezone) kept in

`docs/troubleshooting/06_dc01_fleet_health_and_sysmon.md` , not repeated here.

General lessons: a "Healthy" status can hide multiple stacked root causes — validate across a real reboot, not just current state. Per-hostgroup firewall reachability doesn't generalize across ports. PDC Emulators aren't ordinary NTP clients.

8. Project timeline

Period	What happened
Before 07-05	Fortress Bazzite: virt-manager, Kali/Debian, Ubuntu Server, Metasploitable2, Docker, Juice Shop, Burp Suite, Metasploit set up. Design doc planning a Suricata+Zeek+Wazuh stack.
07-03 – 07-07	Kali/Metasploitable2 VMs up, <code>pentest-lab</code> network built. Metasploitable2 enumerated and exploited (<code>vsftpd_234_backdoor</code> → Meterpreter). Juice Shop deployed, first vuln found via Burp Suite. AX210 WiFi passed through to Kali. Host-level Suricata installed as a side experiment (<code>/var/home/Joost/FORTRESS/</code> , separate from this repo). OPNsense installed 07-07 (redone with ZFS after a failed first attempt); WAN/DHCP issues left open.
07-08	Transition to "SOC Homelab" naming ( reconstructed from limited evidence).
07-09	First git commit. Fixed libvirt/OPNsense DHCP conflict (§7.8); Kea DHCP reservations created; launchers fixed for KDE/Konsole.
07-10	DC01 built (AD DS + DNS, promoted, users created), enrolled in Fleet. First Fleet issue "fixed" non-persistently (see §7.6).
07-11	Full documentation structure created (README, rules, AI policy, network/server/AD docs, troubleshooting history).
07-12	Secret scrubbed from git history. Desktop launchers rebuilt properly. Traffic mirroring rewritten (deadlock fix). Browser automation for Security Onion built.
07-13	DC01 Fleet outage fully resolved. Live lab verification pass (IPs, AD structure, hardware). Documentation substantially expanded, including this master document, its AI-rules and attack-scope sections. Commit made, not pushed (standing instruction: no push without explicit permission).

9. Asset inventory

Full detail: `docs/ASSET_INVENTORY.md`.

Physical host

Property	Value
OS	Bazzite Linux
CPU	Intel Core i9-11900K (8c/1s)
GPU	NVIDIA GeForce RTX 3090
RAM	62 GiB
WiFi	Intel AX210 (Wi-Fi 6E)
Virtualization	KVM, QEMU, libvirt, virt-manager

Virtual machines

VM name (virsh)	IP	SSH	OS / role
OPNsense-FW	.1	opnsense /root	Firewall/gateway
DC01	.10	dc01 /Administrator	Windows Server 2022, AD DC, domain pentest.lab
WIN11-01	.20	none	Windows 11, domain-joined as DESKTOP-EFKB8GQ
SOC-SecurityOnion	.30	security-onion /socadmin	Security Onion 3.1.0 standalone
ubuntu-server-01	.40	ubuntu-server /ubuntu (no key auth)	Linux server, live Juice Shop on :3000
ATTACK-Kali	.50	kali /blue1	Red Team workstation
Target- Metasploitable2	.70	none	Vulnerable target, stock fingerprint

Active Directory identity inventory

OU	Accounts
Domain Controllers	DC01
Admins	IT Admin 01 (not in Domain Admins)
AD-Users	soctest, Helpdesk 01, Employee 01, Manager 01, HR 01, Finance 01
Service-Accounts	SQL Service
Workstations / Servers	(empty)

Custom groups: SOC-Analysts (soctest), Helpdesk (no members). Domain Admins = built-in Administrator only.

Software versions

Security Onion 3.1.0 · Elastic Agent 9.3.3+build202604082258 · Sysmon 15.21 (schema 4.91, SwiftOnSecurity config) · Windows Server 2022 Standard Evaluation (DC01).

Access methods (no passwords stored here)

SSH keys (`~/.ssh/config`) — passwordless for dc01/security-onion/kali; broken for opnsense/ubuntu-server. Browser session (Playwright, dedicated profile) for Security Onion/Kibana/Fleet. `virsh -c qemu:///system` for VM management.

Open items

- opnsense SSH password-only by design (confirmed via audit, not a regression) — key auth could still be added for convenience if desired.
- OPNsense's own config-revision history is empty (no built-in rollback safety net) and it hasn't checked for firmware updates since install — see `docs/OPNSENSE_AUDIT_2026-07-13.md`.
- The KALI firewall alias in OPNsense still points at Kali's old IP (`.157`) — harmless (unused in any active rule) but worth cleaning up.
- ubuntu-server-01 SSH key login doesn't work — needs a password or fresh `ssh-copy-id`.
- WiFi PCI-passthrough to Kali not reconfirmed.
- WIN11-01's intended training purpose — see [§12](#).

10. Glossary

Active Directory (AD) — Microsoft's user/computer/permission management system ("domain"). Runs on DC01; domain `pentest.lab`.

Agent — a program collecting/forwarding data (logs, metrics) to a central system (see Elastic Agent).

Beats — Elastic's lightweight data shippers; run inside Elastic Agent in modern deployments.

CEST/CET — Central European (Summer) Time; UTC+1 winter, UTC+2 summer.

Dead Letter Queue (DLQ) — where Logstash puts documents it couldn't store in Elasticsearch. A growing counter signals a downstream problem even without a sender-side error.

Domain Controller (DC) — AD server managing users/computers. Here: DC01.

Elastic Agent — collects Windows Event Logs/Sysmon/metrics on DC01 and ships to Security Onion; multiple components, each with its own health status.

Elastic Defend — Elastic Agent's endpoint-security (EDR) component; own Fleet connection (port 3765, hostgroup `endgame`).

Elasticsearch — Security Onion's log database; always UTC-internal.

Firewall hostgroup/portgroup — [§5.4](#). Hostgroup = named IP group, portgroup = named port group; Security Onion's firewall links them.

Fleet / Fleet Server — Kibana/Elastic's agent-management layer; server side runs on Security Onion, port 8220.

Hunt — Security Onion's own search UI (like Kibana Discover).

KVM/QEMU/libvirt — this lab's virtualization stack (kernel tech / hardware emulation / management layer).

NTP — clock-sync protocol; DC01 uses `pool.ntp.org`.

PDC Emulator — AD role: normally the domain's authoritative time source. DC01 holds it (the lab's only DC).

Security Onion — this lab's SOC platform (Suricata, Zeek, Elasticsearch, Kibana, Fleet). VM `SOC-SecurityOnion`, .30.

SIEM — collects/correlates logs across sources to find incidents. Security Onion is this lab's SIEM.

Sigma rule — general-purpose log detection rule format (Suricata's equivalent for network traffic).

so-firewall — CLI for Security Onion's own firewall (hostgroup membership). [§5.4](#).

Sysmon — Sysinternals tool logging detailed Windows events far beyond the standard Event Log. On DC01 since 2026-07-13, SwiftOnSecurity config.

UTC — global time standard, no offset. Elasticsearch always stores UTC internally.

vmctimesync — hypervisor clock-sync service (Hyper-V-compatible, also active under QEMU/KVM). Disabled on DC01 — was overriding NTP at boot.

Zeek (formerly Bro) — records network activity (DNS, HTTP, TLS, connections); complements Suricata's attack-pattern focus.

11. Current project status / what's next

Full detail: `docs/PROJECT_STATUS.md`.

✓ Done

Base infrastructure (all 7 VMs on `pentest-lab`) · event-driven traffic mirroring · AD operational · Security Onion operational (web UI, Kibana, Fleet, Hunt) · DC01 Healthy in Fleet, survives restarts/reboots · passwordless SSH to security-onion/kali/dc01 · four desktop launchers · read-only web-audit script · this documentation structure · live network/asset/AD verification pass (2026-07-13).

⚠ Open

`opnsense` SSH not passwordless · `ubuntu-server-01` SSH key login broken · DHCP ranges/DNS forwarders undocumented · Security Onion OS-level timezone still UTC (cosmetic, blocked on root scope) · AD structural gaps (empty `Helpdesk` group, `IT Admin 01` not elevated, undifferentiated role accounts, empty `Workstations / Servers` OUs) — **to be deliberately fixed as part of §12**, not left as-is · the full §12 test pass, AD escalation-path build, and WIN11-01 cleanup are scoped and agreed but **not yet executed** — pre-change snapshots already taken (`DC01` : `2026-07-13-pre-ad-escalation-path` , `WIN11-01` : `2026-07-13-pre-target-cleanup`).

✗ Planned

Detection engineering confirmation ([§6.3](#)) · combined host/security/gaming dashboard · four-tier alerting (INFO/WARNING/HIGH/CRITICAL) with Discord/Telegram forwarding · VLAN segmentation, separate mgmt/attack networks, additional Windows clients, honeypots, periodic Purple Team exercises.

Keeping this current

Every important change: update the specific source doc → `CHANGELOG.md` → `docs/PROJECT_STATUS.md` → a daily report in `docs/daily/` → this master document.

12. Attack scope: agreed Red Team test plan

Scope agreed with Joost 2026-07-13; execution deliberately deferred to a dedicated session.

Grounded in the live-verified lab state above — nothing generic. Everything stays inside `192.168.50.0/24`, launched from Kali, against only the lab's own systems.

Agreed order:

- Tier 1 + 2 together, first** — recon/enumeration plus exploitation of the intentionally-vulnerable targets (Metasploitable2, Juice Shop). Low risk, closes most of §6.1's ⚠️ rows.
- AD attack chain (Tier 3) — build the escalation path first.** The environment currently has none (IT Admin 01 isn't a Domain Admin). Before Kerberoasting/privilege-escalation practice: set an SPN on SQL Service, give IT Admin 01 real elevated rights. This is an infrastructure change — full change procedure (§4), its own explained/confirmed step, not bundled into the attack.
- WIN11-01 becomes a target too, after cleanup** — move DESKTOP-EFKB8GQ into OU=Workstations, general tidy-up, *then* deliberately loosen its firewall for lateral-movement testing (WIN11-01 → DC01).

Preparation already done: pre-change snapshots (DC01 : 2026-07-13-pre-ad-escalation-path, WIN11-01 : 2026-07-13-pre-target-cleanup). One `nmap -sn` sweep run (confirmed known IPs only); a Metasploitable2 full-port scan was started and deliberately stopped at Joost's request. **No exploitation, AD changes, or firewall changes executed yet.**

Tier 1 — Reconnaissance & enumeration

Scenario	Target	Technique
Full port/service scan	Metasploitable2 (.70)	<code>nmap -sV -sC -p-</code>
Web app recon	Juice Shop (.40:3000)	<code>nikto</code> , <code>gobuster</code> / <code>ffuf</code>
AD/domain enumeration	DC01 (.10)	<code>enum4linux-ng</code> , <code>netexec smb</code> , anonymous LDAP
Network sweep	<code>.0/24</code>	<code>nmap -sn</code>

Tier 2 — Exploitation of intentionally-vulnerable targets

Scenario	Target	Technique
vsftpd backdoor	Metasploitable2:21	<code>vsftpd_234_backdoor</code> (repeats the historical exploit, §8)
Samba/NFS/RMI	Metasploitable2	<code>usermap_script</code> , anonymous NFS mount, Java-RMI deserialization
OWASP Top 10	Juice Shop	SQLi, broken auth, IDOR, XSS — built-in scored challenges
UnrealIRCd backdoor	Metasploitable2:6667	Known backdoor trigger

Tier 3 — Active Directory attack chain (after the escalation-path build)

Scenario	Target	Technique
Password spraying	DC01	Common passwords, low attempts/account
Kerberoasting	DC01	TGS request for <code>SQL Service</code> , crack offline (needs the SPN)
AS-REP roasting	DC01	Needs an account with Kerberos pre-auth disabled (none exists yet)
Lateral movement	WIN11-01 → DC01	From an assumed foothold — worth testing against the current locked-down firewall first
Golden/Silver ticket	DC01	Capstone — needs prior privileged access

Execution checklist: Tier 1+2 → cross-check Hunt, flip [§6.1](#) statuses → build the AD escalation path (explained/confirmed) → clean up WIN11-01, loosen its firewall → run Tier 3 + lateral movement → update §6.1/§11 with results.

Document index

Root: README.md , LAB_OVERVIEW.md , PROJECT_RULES.md , AI_ACCESS_POLICY.md , NETWORK.md , SERVERS.md , SECURITY.md , ACTIVE_DIRECTORY.md , CHANGELOG.md . docs/ : INDEX.md , ASSET_INVENTORY.md , GLOSSARY.md , PROJECT_STATUS.md , OPNSENSE_AUDIT_2026-07-13.md , decisions/*.md , guides/*.md (11 files), troubleshooting/01 – 06 , chat_history/*.md (6 files), daily/*/ .

pentest.lab - by Joost Hebly.md (repo root) is an earlier, unmerged concatenation of the same sources, built for the portfolio deliverable — this document supersedes it as the synthesized reference.